



WorkWise

セキュリティルール仕様書

TOYOTA MOBILITY PARTS KANAGAWA BRANCH

概要

本ドキュメントは、WorkWiseアプリケーションにおけるGoogle Firestore（データベース）のセキュリティルール、およびアプリケーションレベルでの権限管理について解説するものです。

セキュリティの階層構造

本システムのセキュリティは、以下の2つの層で管理されています。

- データベース層 (Firestore Security Rules)
 - 不正アクセスやサイバー攻撃を防ぐための「防壁」です。
 - システムを利用する全ユーザー（アプリ利用者）に対して、最低限のアクセス権を付与します。
- アプリケーション層 (Role-Based Access Control)
 - 業務上の役割（管理者/スタッフ）に応じた「機能制限」です。
 - 画面の表示や操作の可否を制御します。

1. データベース層のルール

Firestoreのセキュリティルールでは、「認証済みユーザー（アプリ利用者）」であることをアクセスの基本条件としています。

定義: 「認証済みユーザー」とは

本システムにおいて「認証済みユーザー」とは、WorkWiseアプリをブラウザで開き、裏側で自動的に行われる匿名認証に成功したユーザーを指します。

管理者権限の有無にかかわらず、アプリを開いた全ユーザーがこれに該当します。

コレクション別ルール詳細

データ種別	パス	アクセス許可	備考
----	----	----	----
スタッフ情報	<code>/staff/{staffId}</code>	本人のみ	他者の個人情報は閲覧不可
顧客情報	<code>/customers/{id}</code>	全員(認証済み)	共有データのため全員閲覧可
シフト情報	<code>/workSchedules/{id}</code>	全員(認証済み)	全体のシフトを共有するため
アクションログ	<code>/employeeActions/{id}</code>	全員(認証済み)	業務履歴として共有
勤怠データ	<code>/daily_attendance/{id}</code>	全員(認証済み)	日次集計のため共有

2. アプリケーション層のルール (管理者 vs スタッフ)

データベース層で許可されたアクセスの範囲内で、アプリケーションのプログラムによって以下の権限分けが行われています。

権限マトリクス

| 機能 / 操作 | 管理者 (Admin) | 現場スタッフ (Staff) |

| :--- | :--- | :--- |

| 全体スケジュールの閲覧 | ○ | ○ |

| 自分のタスク編集 | ○ | ○ |

| 分析レポートの閲覧 | ○ | × (非表示) |

| マスタデータ編集 | ○ (GAS側) | × |

| 他者のパスワード変更 | ○ (GAS側) | × |

補足:

WorkWiseでは、ユーザーの役割 (Role) 判定をGoogleスプレッドシート上のスタッフマスタで行っています。

アプリケーションはログイン時にこの役割情報を読み込み、メニューの出し分け (分析レポートの非表示など) を行っています。

まとめ

- 外部からの攻撃に対しては、Firestoreのセキュリティルールが「アプリ利用者以外お断り」として機能します。
- 内部の業務権御に対しては、アプリケーションのロジックが「管理者には全機能、スタッフには現場機能」を提供します。

この二段構えの構成により、利便性と安全性のバランスを確保しています。